

AUDITORÍA DE CIBERSEGURIDAD

Modelado de Amenazas: Framework PASTA (Aplicación Móvil)

Autor: Ing. Mauro Alejandro Guadarrama García

Ingeniero en Sistemas Computacionales

Proyecto de Portafolio

Certificado Profesional de Ciberseguridad de Google

Junio 2026

Hoja de Trabajo: Análisis PASTA - App de Zapatillas

Objetivos Empresariales	La aplicación debe conectar a vendedores y compradores sin problemas, procesando pagos de forma rápida y clara para evitar problemas legales. Es fundamental garantizar la privacidad y seguridad de los datos de los usuarios durante el registro y gestión de las cuentas para generar confianza, así como habilitar mensajería directa y un sistema de calificación.
Alcance Técnico	De las tecnologías evaluadas (API, PKI, AES, SHA-256, SQL), se priorizan SQL y la API . Las APIs gestionan el flujo constante e interactivo de datos entre la aplicación y los servidores, mientras que SQL es la tecnología central que almacena la información crítica del inventario y los datos personales. Una vulnerabilidad en estas áreas expondría inmediatamente los activos más valiosos del negocio.
Análisis de Amenazas	Los principales vectores de ataque externo identificados incluyen el riesgo de Inyección SQL (SQLi) , donde actores maliciosos intentarían manipular la base de datos; y el secuestro de sesión (Session Hijacking) , dirigido a interceptar las comunicaciones para tomar el control de las cuentas de compradores o vendedores legítimos.
Análisis de Vulnerabilidades	El entorno presenta vulnerabilidades a nivel de código base por la falta de declaraciones preparadas (prepared statements) en las consultas a la base de datos, lo cual habilita inyecciones directas. Asimismo, el sistema tolera credenciales de inicio de sesión débiles , lo que facilita enormemente el compromiso del control de acceso a las cuentas.
Análisis de Riesgos y Controles	Para mitigar estos riesgos, la empresa debe implementar controles técnicos rigurosos: (1) Forzar el uso de declaraciones preparadas o consultas parametrizadas en todo el código para prevenir inyecciones SQL. (2) Implementar Autenticación Multifactor (MFA) y políticas de contraseñas complejas. (3) Aplicar cifrado estandarizado (AES y PKI) en la transferencia de datos para proteger tokens y prevenir secuestros de sesión. (4) Ejecutar validación estricta de entradas (input validation) en todas las llamadas a la API.